

UNIVERSIDAD NACIONAL FEDERICO VILLARREAL
FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



INFORME:

Metodologías de prueba de penetración en virtual machine kali linux

CURSO - SECCIÓN:

Ciberseguridad - B

DOCENTE:

Villafuerte Barreto Oswaldo Hernan

ALUMNO:

Mayta Laura Enzo Ivan

1. Metodologías de Pruebas de Penetración

1.1 MITRE ATT&CK

Es una matriz de conocimiento globalmente accesible que documenta las tácticas y técnicas de los adversarios basadas en observaciones del mundo real. A diferencia de otras metodologías que se enfocan en pasos a seguir, ATT&CK se utiliza como un mapa para comprender el comportamiento de un atacante (TTPs), permitiendo emular amenazas específicas y verificar si sus sistemas de detección y respuesta son capaces de detener comportamientos maliciosos concretos en cada fase de un ataque.

Enfoque:

- Basado en comportamiento de adversarios
- Orientado a detección y respuesta

Uso en pentesting:

- Simulación de ataques reales (red team)
- Evaluación de defensas existentes

1.2. OWASP Web Security Testing Guide (WSTG)

Representa el marco de trabajo más completo para evaluar la seguridad de aplicaciones y servicios web. Esta guía detalla un conjunto de pruebas técnicas que cubren todo el ciclo de vida de una aplicación, desde la fase de desarrollo hasta el despliegue. Se enfoca en identificar vulnerabilidades críticas como errores de lógica de negocio, fallos en la autenticación y debilidades en la configuración del servidor, siendo el estándar de referencia para los auditores de aplicaciones web.

Enfoque:

- Vulnerabilidades web (inyecciones, auth, sesiones)
- Metodología estructurada por fases

Uso:

- Pentesting web
- Auditorías de aplicaciones

1.3. NIST SP 800-115

Es una guía técnica de nivel gubernamental que proporciona principios fundamentales para la planificación y ejecución de pruebas de seguridad de la información. Su enfoque es más organizativo que procedimental, definiendo cómo las instituciones deben integrar las pruebas de penetración y el escaneo de vulnerabilidades dentro de sus procesos de gestión de riesgos. Es ideal para organizaciones que buscan un marco formal y estructurado que garantice que las evaluaciones de seguridad sean consistentes y cumplan con estándares de cumplimiento normativo.

Enfoque:

- Planificación, ejecución y reporte

- Alto nivel y formal

Uso:

- Entornos corporativos y gubernamentales
- Auditorías formales

1.4. OSSTMM

Se distingue por ser una metodología basada en la ciencia y la medición precisa de la seguridad operativa. En lugar de limitarse a encontrar vulnerabilidades, este manual se centra en cuantificar el nivel de protección de una organización a través de canales físicos, humanos y digitales, y medir la superficie de ataque mediante métricas exactas. Es una herramienta para aquellos que necesitan presentar resultados estadísticos y verificables sobre la efectividad de sus controles de seguridad.

Enfoque:

- Métricas (RAV – Risk Assessment Values)
- Cobertura amplia (físico, humano, redes)

Uso:

- Auditorías completas
- Evaluación objetiva de seguridad

1.5. PTES

Fue diseñada para estandarizar la ejecución de las pruebas de penetración, asegurando que el cliente reciba un análisis que aporte valor real al negocio. Esta metodología se divide en siete etapas clave que van desde la pre-interacción hasta el informe final, destacando especialmente por su profundidad en el modelado de amenazas y la post-explotación. Su objetivo es que el auditor no solo encuentre un agujero de seguridad, sino que demuestre el impacto económico o estratégico que tendría dicho fallo para la empresa.

Enfoque:

- Ciclo completo del pentest
- Enfoque técnico y realista

Fases clave:

- Reconocimiento
- Explotación
- Post-explotación

1.6. ISSAF

Es una estructura de evaluación extremadamente detallada que vincula las necesidades de seguridad con las herramientas y técnicas específicas para evaluarlas. Se organiza en dominios que cubren desde la seguridad de la red hasta los sistemas operativos y las bases de datos.

Enfoque:

- Muy técnico y extenso
- Incluye herramientas y procedimientos

Uso:

- Pentesters avanzados
- Auditorías profundas

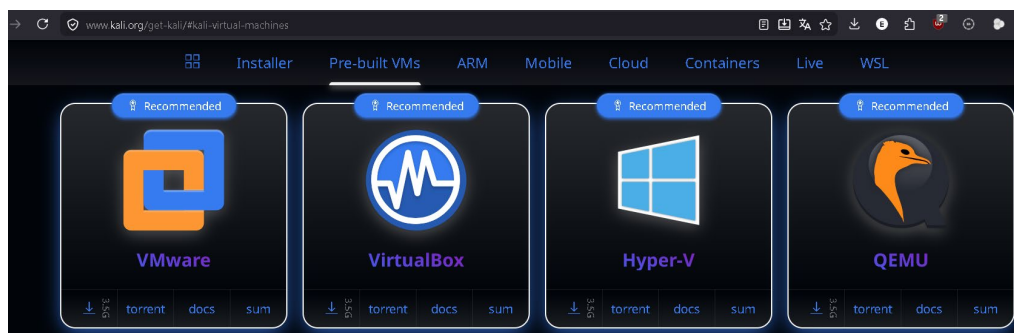
Estas metodologías enseñan que la ciberseguridad no es un proceso que engloba todos escenarios. La elección de una u otra depende totalmente de qué estés protegiendo y qué nivel de profundidad necesites alcanzar.

2. Máquina Virtual Kali Linux

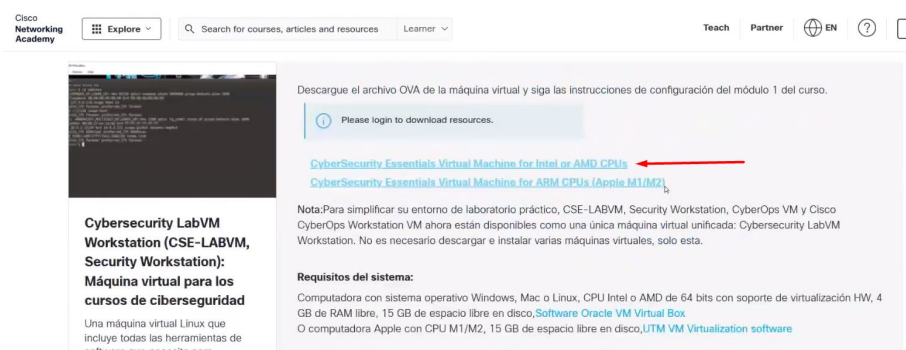
Está diseñada específicamente para la auditoría y seguridad informática. Es un sistema operativo donde ya viene preinstalada con cientos de herramientas para realizar pruebas de penetración, investigación forense e ingeniería inversa.

2.1 Instalación MV Kali Linux

Para descargar el ISO del sistema operativo nos dirigimos a la misma pagina de Kali donde descargar la version respectiva para la máquina virtual a utilizar.

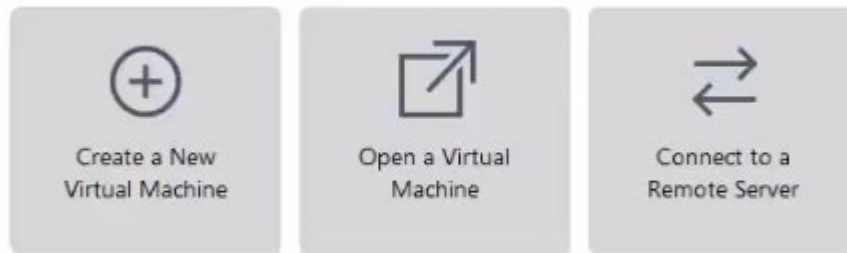


Otra opción es desde el mismo curso de Netacad, descargar el archivo señalado en pantalla.

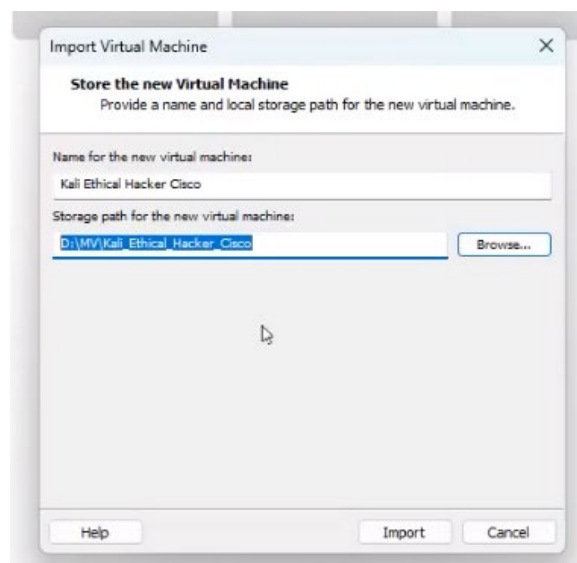


Ya sea la opción 1 o 2, se importará el ISO a la máquina virtual

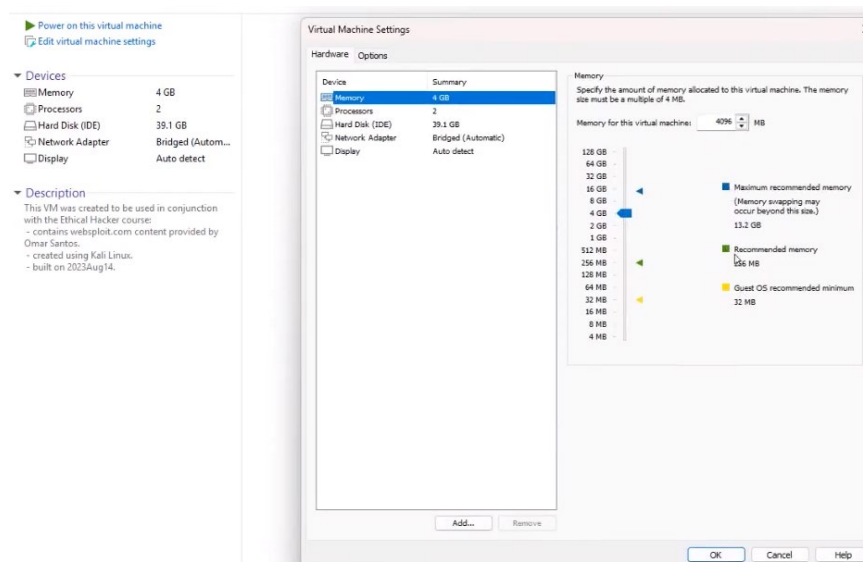
WORKSTATION PRO™ 17



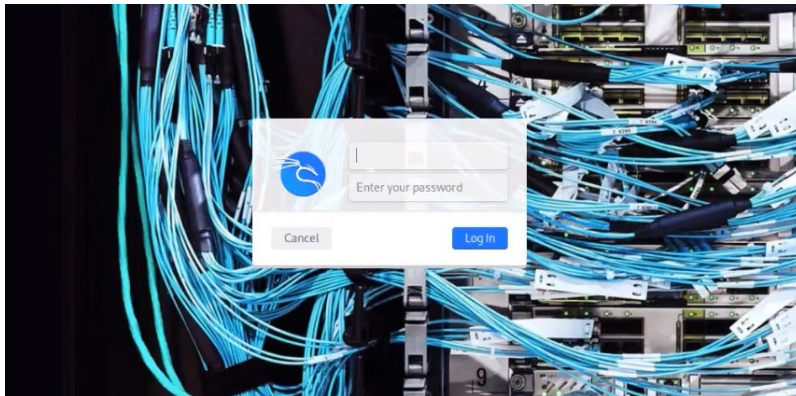
Al seleccionar “Open a Virtual Machine” saldrá la siguiente venta, donde pedirá el nombre que le pondrás a la MV y el directorio donde se encuentra el ISO.



Una vez hecho saldrá la siguiente ventana para asignar los recursos que le daremos al VM



Una vez termine de cargar el VM, en la pantalla de inicio pedirá usuario y contraseña, donde este mismo son el mismo nombre del ISO “Kali”



Esto es en el caso de la 2da opción de importación, si se hizo uso de la 1ra opción saldrá de la siguiente manera la carga del ISO.



En esta ventana, se escoge la instalación gráfica, ya que con esta opción se mostrara con la interfaz grafica y no solo los comandos.



Una vez hecha la instalación nos retornaría hacia el escritorio principal, y si se asignó alguna contraseña o usuario, pediría dicha información para ingresar al escritorio.

2.2 Test Kali VM

Listando el contenido dentro de la carpeta imagenes

```
Archivo Acciones Editar Vista Ayuda
(kali@kali) ~/Imágenes
$ ls
fondo.jpeg wallhaven-5d6oe3.jpg

(kali@kali) ~/Imágenes
$ ls -l
total 632
-rw-r--r-- 1 kali kali 11469 mar 17 01:51 fondo.jpeg
-rw-r--r-- 1 kali kali 634008 mar 17 01:53 wallhaven-5d6oe3.jpg

(kali@kali) ~/Imágenes
$
```

Prueba de conexión ping a Google

```
Archivo Acciones Editar Vista Ayuda
kali@kali: ~/Descargas

(kali@kali) ~/Descargas
$ ping -c 5 google.com
PING google.com (142.251.133.110) 56(84) bytes of data:
64 bytes from ncboga-aj-in-f14.1e100.net (142.251.133.110): icmp_seq=1 ttl=117 time=10.8 ms
64 bytes from ncboga-aj-in-f14.1e100.net (142.251.133.110): icmp_seq=2 ttl=117 time=7.51 ms
64 bytes from ncboga-aj-in-f14.1e100.net (142.251.133.110): icmp_seq=3 ttl=117 time=7.69 ms
64 bytes from ncboga-aj-in-f14.1e100.net (142.251.133.110): icmp_seq=4 ttl=117 time=24.9 ms
64 bytes from ncboga-aj-in-f14.1e100.net (142.251.133.110): icmp_seq=5 ttl=117 time=7.52 ms

— google.com ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4007ms
rtt min/avg/max/mdev = 7.512/11.675/24.889/6.721 ms

(kali@kali) ~/Descargas
$
```